

Dependency & Supply-Chain Audit Trail

Project: `vulnerable-invoice-service` · Full Pipeline Run · Generated 2026-06-28 · SHA `61ed8c3`

Executive Summary

HIGH RISK → REMEDIATED

This report covers the complete Stage 1–4 pipeline run against `vulnerable-invoice-service`. The project entered the run with **79 CVEs** across 9 artifacts and 2 active supply-chain signals. The auto-remediation stage cleared **76 of 79 CVEs** (96%), removed both supply-chain issues, and produced a single consolidated PR for human review.

Stage	Result
Stage 1 — Dependency Scan	79 CVEs across 9 artifacts, 2 supply-chain alerts
Stage 2 — Risk Scoring	Overall band: HIGH · 6 HIGH, 3 MEDIUM items
Stage 3 — Auto-Remediation	9 of 10 candidates auto-applied · 1 MAJOR_REVIEW deferred
Stage 4 — Merge Gate	Pending (runs on PR — gate-only)

Stage 1 — Dependency Scan

Scan timestamp: 2026-06-28T06:19:00Z

Source SHA: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`

Scanner: OWASP Dependency-Check (NVD v11.0)

Metric	Pre-fix
Total dependencies	24
Vulnerable artifacts	9
Total CVEs	79
CRITICAL CVE dependencies	2
HIGH CVE dependencies	4
MEDIUM CVE dependencies	3
Supply-chain alerts	2
Outdated dependencies	8
License violations (WARN)	1

Report: `CVE-Report.md` / `CVE-Report.pdf`

Stage 2 — Risk Scoring

Overall risk band: **HIGH**

Rank	Coordinate	Risk Score	Band	Key CVE
------	------------	------------	------	---------

1	log4j-core:2.14.1	7.8	HIGH	CVE-2021-44228 (CVSS 10.0)
2	jackson-databind:2.9.8	7.8	HIGH	CVE-2019-14379 (CVSS 9.8)
3	mysql-connector-java:8.0.30	7.6	HIGH	CVE-2023-22102 (CVSS 8.3)
4	log4j-api:2.14.1	6.8	HIGH	CVE-2026-34479 (CVSS 7.5)
5	protobuf-java:3.19.4	6.7	HIGH	CVE-2024-7254 (CVSS 7.5)
6	guava:24.1.1-jre	6.3	HIGH	CVE-2023-2976 (CVSS 7.1)
7	jackson-annotations:2.9.0	5.5	MEDIUM	CVE-2018-1000873 (CVSS 6.5)
8	commons-io:2.4	5.2	MEDIUM	CVE-2021-29425 (CVSS 4.8)
9	commons-lang3:3.4	5.2	MEDIUM	CVE-2025-48924 (CVSS 5.3)

Report: Risk-Scoring-Report.md / Risk-Scoring-Report.pdf

Stage 3 — Auto-Remediation

Branch: fix/depSCAN-20260628-062536

Build verification: mvn clean test — 2/2 PASS

Pre-existing gate: mvn verify fails on JaCoCo 80% coverage gate (ISSUE #6, intentional in this demo project — not caused by these bumps)

Fixes Applied

#	Coordinate	Change	Type	CVEs Cleared	Band
1	com.fastxml.jackson.core:jackson-databind	REMOVED (typosquat)	Supply-chain removal	n/a	CRITICAL
2	http://insecure-mirror.example.net/maven2	REMOVED (HTTP repo)	Supply-chain removal	n/a	HIGH
3	log4j-core:2.14.1 → 2.17.1	Version bump	minor (2.x)	CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), +6 more	HIGH
4	log4j-api:2.14.1 → 2.17.1	Version bump	lockstep	CVE-2026-34479 (7.5), CVE-2026-34477 (5.9)	HIGH
5	jackson-databind:2.9.8 → 2.17.1	Version bump	within-major (2.x)	CVE-2019-14379 (9.8) + 53 more	HIGH
6	mysql-connector-java:8.0.30 → 8.0.33	Version bump	patch	CVE-2023-22102 (8.3)	HIGH
7	commons-io:2.4 → 2.14.0	Version bump	minor	CVE-2021-29425 (4.8), CVE-2024-47554 (4.3)	MEDIUM
8	commons-lang3:3.4 → 3.14.0	Version bump	minor	CVE-2025-48924 (5.3)	MEDIUM
9	protobuf-java:3.19.4 → 3.25.5	DependencyMgmt pin	minor (3.x)	CVE-2024-7254 (7.5), CVE-2022-3171 (7.5), +2 more	HIGH
10	jackson-annotations:2.9.0 → 2.17.1	DependencyMgmt pin	within-major (2.x)	CVE-2018-1000873 (6.5)	MEDIUM

Deferred — Human Follow-up Required

Item	Coordinate	Reason	Action
MAJOR_REVIEW	guava:24.1.1-jre	Fix requires major version jump 24 → 32 (API-breaking)	Tracking issue opened

76 of 79 CVEs cleared (96%). Remaining 2 CVEs (guava CVE-2023-2976, CVE-2020-8908) deferred to MAJOR_REVIEW issue.

Stage 4 — Merge Gate

The Stage 4 `pr_validation_agent` runs gate-only on the opened PR. Gate criteria:

Check	Threshold	Expected
<code>mvn test</code>	must pass	PASS (2/2 confirmed)
OWASP Dependency-Check	0 unresolved CRITICAL/HIGH CVEs	PASS (after fixes)
Supply-chain audit (Grype)	no BLOCK findings	PASS (supply-chain removed)

No auto-merge. A PASS verdict means "ready for human review." A human approves and merges.

Human Follow-ups

Priority	Item	Tracking
HIGH	<code>guava:24.1.1-jre</code> → <code>32.x</code> — major version jump, manual API review required	GitHub Issue (MAJOR_REVIEW)
MEDIUM	JaCoCo coverage below 80% (ISSUE #6) — pre-existing, not introduced by this PR	Existing project issue
LOW	<code>mysql-connector-java</code> GPL-2.0 license — requires legal review for permissive-only projects	Note in PR
LOW	<code>log4j-api</code> — further bump to 2.24.3 clears CVE-2026-34479; current 2.17.1 clears Log4Shell	Follow-up bump recommended

Generated by the Dependency & Supply-Chain Plugin — Full Pipeline (Stages 1–4). Branch: `fix/depSCAN-20260628-062536` .